

# Guide de Sécurité - StatDirm

---

Ce document décrit les mesures de sécurité mises en place pour protéger les données sensibles de l'application StatDirm.

## Mesures de Sécurité Implémentées

### 1. Authentification et Autorisation

#### Authentification HTTP Basic (Nginx)

- Configuration d'authentification HTTP Basic via Nginx
- Utilisation de fichiers `.htpasswd` pour gérer les utilisateurs
- **À configurer en production** : Décommenter les lignes dans `nginx.conf`

```
# Générer un fichier .htpasswd
htpasswd -c /etc/nginx/.htpasswd utilisateur
```

#### Authentification Application (AuthGuard)

- Composant `AuthGuard` qui protège toutes les routes
- Vérification de l'authentification au chargement
- Session basée sur `sessionStorage` (à remplacer par JWT en production)

### 2. Headers de Sécurité HTTP

Les headers suivants sont configurés dans `nginx.conf` :

- **X-Frame-Options:** `DENY` - Empêche le clickjacking
- **X-Content-Type-Options:** `nosniff` - Empêche le MIME-sniffing
- **X-XSS-Protection:** `1; mode=block` - Protection contre XSS
- **Referrer-Policy:** `strict-origin-when-cross-origin` - Contrôle des référents
- **Content-Security-Policy:** Politique stricte pour limiter les ressources
- **Strict-Transport-Security (HSTS):** Activé en HTTPS

### 3. Protection des Données Sensibles

#### Masquage des Données

- Fonctions de masquage dans `src/utils/security.ts` :
  - `maskName()` : Masque les noms/prénoms
  - `maskId()` : Masque les identifiants
  - `maskDateOfBirth()` : Affiche seulement l'année de naissance

#### Protection des Fichiers JSON

- Blocage de l'accès direct aux fichiers `.json` via Nginx
- Les données sont servies uniquement via l'API de l'application

### 4. Rate Limiting

- Limitation du nombre de requêtes par IP
- Zone `api_limit` : 10 requêtes/seconde avec burst de 20
- Zone `login_limit` : 5 requêtes/minute pour les tentatives de connexion

### 5. HTTPS/TLS

#### Configuration SSL/TLS

- Support TLS 1.2 et 1.3 uniquement
- Cipher suites modernes et sécurisées
- HSTS activé pour forcer HTTPS

#### À faire en production :

1. Obtenir un certificat SSL (Let's Encrypt recommandé)
2. Décommenter la configuration HTTPS dans `nginx.conf`
3. Configurer les chemins vers les certificats

### 6. Validation et Sanitization

- Fonction `sanitizeInput()` pour nettoyer les entrées utilisateur
- Validation des filtres avec `validateFilter()`
- Protection contre les injections XSS et SQL

### 7. Logs et Monitoring

- Logs d'accès Nginx activés
- Logs d'erreur pour le debugging

- Monitoring des tentatives d'accès non autorisées

## Déploiement Sécurisé

### Checklist Pré-Déploiement

- ☐ • Changer le mot de passe par défaut dans `.env`
- ☐ • Configurer l'authentification HTTP Basic dans Nginx
- ☐ • Obtenir et configurer un certificat SSL/TLS
- ☐ • Activer HTTPS et redirection HTTP → HTTPS
- ☐ • Vérifier que les fichiers sensibles ne sont pas accessibles
- ☐ • Configurer un firewall (UFW, iptables, etc.)
- ☐ • Mettre à jour tous les packages ( `npm audit` )
- ☐ • Configurer des sauvegardes régulières
- ☐ • Mettre en place un monitoring (logs, alertes)
- ☐ • Tester l'authentification et les permissions

### Configuration Nginx en Production

#### 1. Créer le fichier `.htpasswd` :

```
htpasswd -c /etc/nginx/.htpasswd admin
```

#### 1. Décommenter l'authentification dans `nginx.conf` :

```
auth_basic "Accès restreint - DIRM Méditerranée";  
auth_basic_user_file /etc/nginx/.htpasswd;
```

#### 1. Configurer HTTPS :

```
# Avec Let's Encrypt  
certbot --nginx -d votre-domaine.fr
```

#### 1. Redémarrer Nginx :

```
nginx -t # Vérifier la configuration
systemctl restart nginx
```

## Variables d'Environnement

Créer un fichier `.env` à partir de `.env.example` et configurer :

```
VITE_APP_PASSWORD=votre-mot-de-passe-fort
NODE_ENV=production
```

## ⚠ Avertissements Importants

1. **Données Sensibles** : Cette application contient des données personnelles (RGPD). Assurez-vous de :
  - Respecter le RGPD
  - Avoir une base légale pour le traitement
  - Informer les personnes concernées
  - Mettre en place des mesures techniques et organisationnelles
2. **Authentification Temporaire** : L'authentification actuelle est basique. En production, implémenter :
  - JWT avec refresh tokens
  - OAuth 2.0 / SAML
  - Authentification multi-facteurs (2FA)
3. **Chiffrement** : Pour des données très sensibles, considérer :
  - Chiffrement au repos (base de données)
  - Chiffrement en transit (HTTPS obligatoire)
  - Chiffrement des exports Excel

## 🔍 Audit de Sécurité

### Tests à Effectuer

1. **Test d'authentification** :
  - Vérifier que l'accès sans authentification est bloqué
  - Tester avec des mots de passe incorrects
  - Vérifier l'expiration de session

## 2. Test des headers de sécurité :

```
curl -I https://votre-domaine.fr
```

## 3. Test de rate limiting :

- Envoyer de nombreuses requêtes rapidement
- Vérifier que le rate limiting fonctionne

## 4. Test d'accès aux fichiers sensibles :

```
curl https://votre-domaine.fr/src/data/agents.json  
# Devrait retourner 403 Forbidden
```

## Support

Pour toute question sur la sécurité, contacter l'équipe technique de la DIRM Méditerranée.

## Ressources

- [OWASP Top 10](#)
- [Guide de sécurité Nginx](#)
- [RGPD - CNIL](#)